

# AEGIS CYBER RISK MANAGER

## Complete BTech Project Interview & Defense Preparation Guide

Candidate: Yadhu Krishna | Track: AI, NLP & Cybersecurity

### 1. 30-Second Elevator Pitch

Aegis is an enterprise-grade Cyber Risk Management platform that bridges the gap between raw machine learning detection and actionable security operations. It utilizes character n-gram TF-IDF vectorization with Logistic Regression to classify web injection attacks in under 1ms, combined with a behavioral sliding-window engine for brute-force attacks. Built on NIST SP 800-30 principles, it computes a composite Risk Score (0-100) based on Likelihood, Severity, and Asset Criticality, streaming live telemetry to an interactive 3D particle SOC dashboard.

### 2. Core Architectural Questions

#### Q1: Why use NLP for Cybersecurity instead of static regex signatures?

Static regex signatures are brittle and easily bypassed using URL encoding (%27%20OR%201=1), character case mutation, or SQL comments. NLP treats HTTP inputs as structured text patterns, learning structural syntax markers rather than rigid strings.

#### Q2: Why character n-grams instead of standard word tokenization?

Web exploit payloads (e.g. ' OR '1'='1, <script>alert(1)) do not consist of natural English dictionary words. Punctuation, quotes, equality signs, and brackets contain critical malicious signals. Character n-grams (sub-strings of 2 to 5 characters) preserve these exact syntax anomalies even across obfuscated inputs.

#### Q3: Why Logistic Regression over a Deep Learning LLM?

Security inspection occurs inline or in real-time streaming. A Large Language Model (LLM) takes 200-1000ms and requires costly GPUs. Our TF-IDF + Logistic Regression model executes inference in under 1 millisecond on commodity CPUs with calibrated probability scores and clear explainability.

#### Q4: Why is a Behavioral Engine necessary alongside NLP?

NLP only analyzes textual content. A single failed login request (username=admin&password=xyz) looks syntactically 100% normal. Only a temporal sliding window tracking state over time can detect that 6 failed 401 logins in 30 seconds from a single IP constitutes a Brute-Force credential attack.

### 3. Risk Engine & Prioritization Questions

#### Q5: How is the Risk Score calculated?

Based on NIST SP 800-30 guidelines: Risk Score (0-100) = Round((Likelihood \* 0.35 + Technical Severity \* 0.35 + Asset Criticality \* 0.30) \* 100).

- Likelihood: Derived from ML prediction confidence and exploit complexity.
- Technical Severity: SQLi (0.95), Brute Force (0.90), Rate Burst (0.75), XSS (0.70).
- Asset Criticality: Payment/Auth (1.0), Admin (0.95), Catalog API (0.8), Search (0.6).

#### Q6: What are the Risk Tiers?

Critical (80-100, Immediate triage), High (60-79, Urgent within shift), Medium (40-59, Elevated anomaly), Low (0-39, Baseline/Informational).

#### **Q7: How does Smart Alerting work?**

Alerts route dynamically: Low = Dashboard only; Medium = Dashboard + Audit log; High = Dashboard + SMTP Email; Critical = Dashboard + Email + Twilio SMS. An in-memory cooldown cache deduplicates alerts to prevent notification flooding.

### **4. Machine Learning & Metric Questions**

#### **Q8: Why is Recall more important than Precision in threat detection?**

Recall measures what percentage of actual attacks were caught ( $TP / (TP + FN)$ ). A False Negative in cybersecurity means an active attacker bypassed the defense and compromised internal databases. While high Precision reduces analyst fatigue, high Recall is vital to prevent breaches.

#### **Q9: What is Concept Drift and how is it mitigated?**

Attack patterns evolve as new vulnerabilities emerge. A model trained on past data may degrade over time (Concept Drift). In production, this is solved by active continuous learning, periodic retraining pipelines, and canary validation.

### **5. Frontend & Real-Time Telemetry**

#### **Q10: How does the 3D Particle Risk Sphere work?**

Rendered using HTML5 Canvas with 550 glowing nodes distributed via a Fibonacci sphere algorithm. Uses 3D perspective projection (fov=400) and smoothly interpolates colors: Green (<40), Yellow/Orange (40-79), Red (>=80), with dynamic ripple waves upon threat arrival.

#### **Q11: Why WebSockets over Polling?**

Polling wastes network bandwidth and CPU by repeatedly querying the server every few seconds. WebSockets maintain a persistent lightweight TCP channel, pushing threat telemetry to the dashboard in under 10 milliseconds with zero polling latency.